

03 Broken User Authentication

Broken User Authentication is a common vulnerability in APIs, since faults in the authentication and identity verification preflowers to act as impersonate legitimate users.

Such breaches can result from inadequate password policies, a lack of restrictions on login attempts, session tokens that aren't adequately protected, or tokens that never expire or aren't properly verified. Attackers can then exploit these flaws by guessing users' passwords, reusing stolen passwords, or hijacking sessions to gain control of accounts.

Use multi-factor authentication, set rate limits, manage secure tokens by keeping their expiry time short, and rely on established authentication frameworks.